

בנק שאלות תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1.  בנק שאלות תרגול (Practice Question Bank)

בנק שאלות תרגול (Practice Question Bank)

שאלות תרגול לכל הקורס — ידע (Knowledge) ותרחישים מעשיים (Scenario). **מפתח התשובות בסוף המסמך.** נסה לענות לבד לפני שתציץ.

השאלות מסודרות לפי מודול. סוגי שאלות: **בחירה** (רב-ברירה), **פתוחה** (תשובה קצרה), **תרחיש** (מה תעשה בסיטואציה).

מודול 1 — מבוא ומתודולוגיה

Q1 (בחירה) מהו הסדר הנכון של חמשת שלבי ההאקিং האתי? (א - Scanning → Recon → Exploitation → Maintaining Access → Covering Tracks) (ב - Recon → Scanning → Gaining Access → Maintaining Access → Covering Tracks) (ג - Recon → Exploitation → Scanning → Maintaining Access → Covering Tracks) (ד - Scanning → Gaining Access → Recon → Covering Tracks → Maintaining Access)

Q2 (פתוחה) מהם שלושת עקרונות ה-CIA Triad?

Q3 (בחירה) בדיקה שבה נותנים לבודק רק שם דומיין, ללא שום מידע נוסף, נקראת: (א - White Box) (ב - Grey Box) (ג - Black Box) (ד - Crystal Box)

Q4 (תרחיש) קיבלת בדיקת חדירות. תוך כדי עבודה גילית שרת פגיע שאינו מופיע ב-Scope. מה מותר ומה אסור לך לעשות?

Q5 (פתוחה) הסבר את ההבדל בין Vulnerability, Exploit ו-Payload.

מודול 2 — יסודות Linux

Q6 (בחירה) איזו פקודה מציגה את כל קובצי ה-SUID במערכת? (א - `find / -type suid`) (ב - `find / -perm -4000 2>/dev/null | xargs ls -l`) (ג - `ls -suid /`) (ד - `chmod 4000`)

Q7 (פתוחה) מה ההבדל בין `>` ל-`>>` בהפניית פלט?

Q8 (בחירה) שורת ההרשאות `-rwxr-x---` שווה לאיזה ערך Octal? (א - 755) (ב - 750) (ג - 640) (ד - 770)

Q9 (תרחיש) השגת גישה למכונת Linux כמשתמש רגיל. מהי אחת הפקודות הראשונות שתריץ כדי לבדוק אפשרות הסלמת הרשאות, ולמה?

Q10 (פתוחה) אילו שני קבצים ב- `/etc` הם היעדים החמים ביותר להאקר, ומה כל אחד מכיל?

מודול 3 — יסודות רשתות

Q11 (בחירה) לחיצת היד של TCP מורכבת מ: א - $\text{ACK} \rightarrow \text{SYN}$ (ב - $\text{ACK} \rightarrow \text{SYN-ACK}$ (ג - $\text{ACK} \rightarrow \text{SYN} \rightarrow \text{FIN}$ (ד - $\text{ACK} \rightarrow \text{SYN} \rightarrow \text{RST}$

Q12 (פתוחה) לאיזה שירות שייך כל פורט: 22, 80, 443, 445, 3389?

Q13 (בחירה) בסריקת nmap, איזו תשובת שרת ל-SYN מעידה שהפורט סגור? - א - $\text{ACK} \rightarrow \text{SYN-ACK}$ (ב - ACK (ג - RST (ד - אין תשובה

Q14 (תרחיש) אתה מקבל את הכתובת 10.0.5.23. האם היא פרטית או ציבורית? לפי איזה טווח?

Q15 (פתוחה) כמה כתובות יש בתת-רשת 24/2? כמה מהן שמישות למארחים?

מודול 4 — סקריפטינג

Q16 (בחירה) בשם Payload, מה מסמן ה- `/reverse_tcp ...` (למשל `.../reverse_tcp`) - א - Non-Staged (ב - Staged (ג - Bind (ד - Encrypted

Q17 (פתוחה) מה מחזירה הפונקציה `connect_ex` ב-Python כשהפורט פתוח?

Q18 (תרחיש) נתון `banner = "Apache/2.4.49"`. כתוב שורת Python אחת שמחלצת רק את 2.4.49.

Q19 (בחירה) איזה מבנה נתונים ב-Python אינו ניתן לשינוי? - א - List (ב - Dictionary (ג - Tuple (ד - Set

מודול 5 — איסוף מידע

Q20 (בחירה) גילוי תת-דומיינים באמצעות Sublist3r הוא סוג של איסוף: - א - אקטיבי (ב - פסיבי (ג - פיזי (ד - הסלמה

Q21 (פתוחה) מהי מטרת ה-OSINT על מיילים, ואיזה כלי משמש לזיהוי תבנית המייל של ארגון?

Q22 (תרחיש) אתה רוצה למצוא קובצי PDF חשופים בדומיין target.com. כתוב את שאילתת Google Dorking.

Q23 (בחירה) Burp Suite פועל בעיקר כ: - א) סורק פורטים · ב) Proxy בין דפדפן לשרת · ג) מפצח סיסמאות · ד) סורק חולשות

מודול 6 — סריקה ומיפוי

Q24 (בחירה) איזו פקודת nmap סורקת את כל 65,535 הפורטים? - א) `nmap -F` · ב) `nmap -p` · ג) `nmap -sn` · ד) `nmap -top`

Q25 (פתוחה) מה עושה הדגל `-sV` ב-nmap, ולמה הוא חשוב לחקר חולשות?

Q26 (תרחיש) nmap הראה פורט 445 פתוח עם Samba. אילו שתי פקודות תריץ כדי למנות אותו לעומק?

Q27 (בחירה) איזה כלי מבצע Directory Brute-Force על שרת web? - א) `enum4linux` · ב) `gobuster` · ג) `searchsploit` · ד) `hydra`

Q28 (פתוחה) מהו הגשר בין "מצאתי גרסת שירות" ל-"יש לי Exploit"? איזה כלי Kali משמש לכך?

מודול 7 — ניצול

Q29 (בחירה) באיזה סוג Shell **הקורבן** יוזם את החיבור אל התוקף? - א) Bind Shell · ב) Reverse Shell · ג) Web Shell · ד) Root Shell

Q30 (פתוחה) מדוע Reverse Shell עוקף חומות אש טוב יותר מ-Bind Shell?

Q31 (תרחיש) ב-Metasploit בחרת Exploit. איזה שלושה פרמטרים חובה תגדיר לפני `exploit`, ומה כל אחד?

Q32 (בחירה) איזה כלי יוצר Payload עצמאי (למשל קובץ exe להעלאה ליעד)? - א) `msfconsole` · ב) `msfvenom` · ג) `searchsploit` · ד) `nmap`

Q33 (תרחיש) קיבלת Shell אך הוא לא יציב ונופל. מה שתי הפעולות שתנסה?

🎯 שאלות אינטגרציה (חוצות-מודולים)

Q34 (תרחיש מלא) קיבלת IP יחיד: 192.168.56.101. תאר את שרשרת הפעולות המלאה שתבצע — צעד אחר צעד — מ-"כלום" ועד "root", תוך ציון הכלי בכל שלב.

Q35 (תרחיש) nmap הראה: `80/tcp open http Apache 2.4.49`. מה כל הצעדים הבאים שלך עד לניסיון ניצול?

Q36 (פתוחה) מדוע אומרים ש-“90% מהעבודה היא Enumeration”? הסבר בהקשר של שרשרת התקיפה.

מפתח תשובות (Answer Key) ✓

Q1 ב. **Q3** Confidentiality, Integrity, Availability. **Q2** ג. (Black Box). **Q4** אסור לתקוף אותו (מחוץ ל-Scope = לא מורשה); מותר ומומלץ לתעד ולדווח ללקוח ולהמליץ להוסיפו ל-Vulnerability **Q5**. Scope=הפגם, Exploit=ניצול הפגם, Payload=הקוד שרץ אחרי.

Q6 ב. **Q7** > דורס/יוצר קובץ; >> מוסיף בסוף מבלי לדרוס. **Q8** ב. (750). **Q9** sudo -l — מציג אילו פקודות מותר להריץ כ-root; הרשאות sudo שגויות = מסלול הסלמה קלאסי. (גם find / -perm -4000 תקין). **Q10** /etc/passwd (רשימת משתמשים, קריא לכולם) ו-/etc/shadow (Hash של הסיסמאות, root בלבד).

Q11 ב. **Q13** 22=SSH, 80=HTTP, 443=HTTPS, 445=SMB, 3389=RDP. **Q12** ג. (RST). **Q14** פרטית — טווח 10.0.0.0/8. **Q15** 256 כתובות, 254 שמישות.

Q16 ב. (Staged). **Q17** 0. (אפס). **Q19** . banner.split("/") [1] **Q18** ג. (Tuple).

Q20 א. (אקטיבי — Sublist3r שולח שאילתות; חלק ממקורותיו פסיביים אך הכלי נחשב לאקטיבי/מעורב). **Q21** לזהות תבנית מייל של הארגון (לפישנינג/Spraying בתוך Scope); הכלי: **Q22** hunter.io. **Q23** site:target.com filetype:pdf ב. (Proxy).

Q24 ב. (-p). **Q25** מזהה גרסאות שירותים; הגרסה מאפשרת חיפוש Exploit ידוע. **Q26** enum4linux -a <ip> ו- //<ip>/ -L smbclient (או nmap smb-scripts). **Q27** ב. (gobuster). **Q28** חקר חולשות; הכלי: searchsploit (מאגר Exploit-DB המקומי).

Q29 ב. (Reverse Shell). **Q30** כי חומות אש מתירות לרוב תעבורה **יוצאת**; ב-Reverse הקורבן יוצר חיבור יוצא אל התוקף. **Q31** RHOSTS (יעד), LHOST (התוקף/Kali), PAYLOAD (הקוד שירוצץ). **Q32** ב. (msfvenom). **Q33** להחליף בין Payload Staged ל-Non-Staged; לייצב Shell עם python pty / upgrade (stty).

Q34 דוגמה: nmap -sn (?) → nmap -sC -sV -p- → מנייה לפי שירות (nikto/gobuster/enum4linux) → searchsploit (Exploit) → Metasploit/ידני (set) → root. **Q35** whatweb/nikto → gobuster=whoami → (exploit → RHOSTS/LHOST/PAYLOAD חולשת searchsploit (Apache 2.4.49 (Path Traversal, CVE-2021-41773) → ניצול. **Q36** כי גילוי יסודי של כל שירות/גרסה/הגדרה קובע אילו Exploits רלוונטיים; דילוג על מנייה = פספוס וקטורי תקיפה והכשלת השלבים הבאים.